A Passive Web Security Assessment Framework: A Cross-National Empirical Study of 131 Government, Banking, Healthcare, News, and E-Commerce Websites Across Six Countries

Independent Research Study

Department of Computer Science / Information Security

Prepared from original passive-scan data collected using the accompanying Python framework (main_file.py)

***Abstract*— Web application security is frequently assessed through active penetration testing, which is invasive, legally constrained, and unsuitable for large-scale, cross-organizational studies. This paper presents a purely passive web security assessment framework that evaluates the externally observable security posture of a website using only standard HTTP(S) GET/HEAD requests, DNS TXT lookups, and public Certificate Transparency logs — without exploitation, fuzzing, brute forcing, or authentication bypass of any kind. The framework audits eleven security-relevant dimensions: HTTP security headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy), cookie attribute hygiene (Secure, HttpOnly, SameSite), TLS/HTTPS enforcement, CORS configuration, Subresource Integrity (SRI) usage, email anti-spoofing controls (SPF/DMARC), security.txt vulnerability-disclosure availability, robots.txt/sitemap exposure, and passive technology fingerprinting. We applied the framework to 131 production websites spanning five critical sectors (Government, Banking, Healthcare, News/Media, and E-Commerce) across six countries — India, the United States, the United Kingdom, Canada, Australia, and Singapore — and produced a weighted 0–100 security score for each site. The mean score across the dataset was 72.96 (σ = 13.21, median = 74), with scores ranging from 18 to 100. Banking (80.4) and Government (78.7) sectors substantially outperformed News/Media (66.4) and E-Commerce (67.0). The United Kingdom achieved the highest national average (76.3), while the United States recorded the lowest (69.4) despite hosting several of the highest-scoring individual sites. Content-Security-Policy was absent on 71.0% of sites, Subresource Integrity was inconsistently applied on 100% of sites with externally hosted scripts, and 63.4% of domains lacked an SPF record, indicating widespread exposure to content-injection and email-spoofing risk even among high-profile organizations. These findings demonstrate that passive, non-invasive reconnaissance can yield statistically meaningful, reproducible, and ethically defensible insight into real-world web security posture at scale, and can serve as a low-cost complement to active penetration testing and compliance auditing.

Index Terms*— *passive reconnaissance, web application security, HTTP security headers, HSTS, Content-Security-Policy, TLS, cookie security, DMARC, security posture scoring, cross-national security assessment.

I. Introduction

Every modern organization — from government ministries to community hospitals — now operates a public-facing website that forms the first point of contact between the institution and the citizens, patients, or customers it serves. The confidentiality, integrity, and availability of these websites is therefore not a purely technical concern but a matter of public trust. Yet the security posture of production websites is rarely measured systematically outside of formal, invasive penetration tests, which are expensive, require explicit legal authorization, and are consequently performed on only a small fraction of the sites that citizens interact with daily.

This study asks a narrower and more tractable question: how much can be learned about the real-world security posture of a website using only information that the website's own server voluntarily discloses during an ordinary browser visit? We refer to this class of technique as passive web security assessment. A passive assessment issues only standard GET/HEAD HTTP(S) requests, reads publicly published DNS TXT records (SPF, DMARC) and public Certificate Transparency (CT) logs, and never attempts to exploit, fuzz, brute-force, or bypass any authentication or access-control mechanism. Because no request is sent that a normal browser would not also send, passive assessment carries negligible operational risk to the target and does not require prior authorization in the way active testing does — although we note in Section VII that ethical and legal diligence remains essential.

We designed and implemented a twelve-module passive assessment framework (Section III) and applied it to 131 production websites drawn from five sectors that citizens depend on most heavily for security-sensitive interactions — Government, Banking, Healthcare, News/Media, and E-Commerce — across six countries with materially different regulatory regimes for data protection and cybersecurity: India, the United States, the United Kingdom, Canada, Australia, and Singapore. Each site was scored on a normalized 0–100 scale derived from eleven weighted security checks, and the resulting dataset was analyzed for patterns by country, by sector, and by individual control.

The contributions of this paper are threefold. First, we present a reusable, open passive-assessment architecture that can be extended with additional passive checks without introducing active-testing risk. Second, we contribute an empirical, reproducible dataset of security postures for 131 real-world websites, which — to the best of our knowledge — is one of the few publicly documented cross-national comparisons of this kind at this sample size. Third, we derive sector- and country-level findings that are directly actionable for security practitioners, auditors, and policymakers, including the observation that Subresource Integrity is effectively unused across the entire sample and that Content-Security-Policy remains absent from the large majority of sites regardless of sector or country.

The remainder of this paper is organized as follows. Section II reviews related work in web security scanning and header-based auditing. Section III describes the framework architecture and each of its twelve modules. Section IV describes the dataset and scoring methodology. Section V presents the empirical results. Section VI discusses the findings in depth. Section VII addresses threats to validity and ethical considerations. Section VIII concludes and outlines future work.

II. Related Work

Automated web security assessment has historically been dominated by active vulnerability scanners such as OWASP ZAP, Nikto, and commercial DAST (dynamic application security testing) tools, which send crafted or malformed requests to elicit exploitable behavior. These tools are effective but require authorization, can trigger web-application-firewall (WAF) alerts or denial-of-service side effects, and are impractical to run at the scale of hundreds of third-party sites the researcher does not control.

A complementary line of work focuses on passive, header-based auditing. Public services such as SecurityHeaders.io and the Mozilla Observatory popularized the idea of scoring a site purely from its HTTP response headers, and academic studies have used similar header-presence heuristics to study HSTS and CSP adoption at Internet scale using crawls of the Alexa/Tranco top-list. Separately, TLS-observatory-style projects (e.g., SSL Labs) passively inspect certificate chains and negotiated TLS parameters without active exploitation. Certificate Transparency logs, mandated for publicly trusted certificates since 2018, have independently been used for passive subdomain enumeration in reconnaissance research.

Our framework differs from these prior efforts in two respects. First, rather than focusing on a single dimension (headers, or TLS, or DNS), it aggregates eleven passive signal categories — headers, cookies, TLS/HTTPS, CORS, SRI, email anti-spoofing (SPF/DMARC), security.txt, robots.txt exposure, technology fingerprinting, network/geolocation metadata, and CT-log subdomain enumeration — into a single weighted score, giving a more holistic picture of posture than any one signal alone. Second, rather than crawling a generic top-list, we deliberately construct a stratified sample across five high-stakes sectors and six countries, enabling sector-level and cross-national comparison that generic Alexa-scale studies do not directly support.

III. Framework Architecture and Methodology

A. Design Principles

The framework was built around three non-negotiable design constraints. (1) No exploitation: no request is ever sent that attempts to trigger a vulnerability, bypass authentication, inject a payload, or fuzz an endpoint. (2) No active probing beyond a normal page load: the tool issues the same GET/HEAD requests, TLS handshake, and DNS TXT lookups

a standard browser or resolver would perform. (3) Read-only analysis: all findings are derived by parsing information the target already discloses — response headers, HTML markup, robots.txt, DNS TXT records, and public CT logs — never by actively enumerating hidden resources.

B. Module Overview

The framework is organized as twelve independent modules orchestrated by a central controller, summarized in Table I.

TABLE I

#	Module	Function
1	HTTP Header Analyzer	Retrieves raw response headers via a single GET request
2	Technology Fingerprinter	Identifies server software, CMS, and JS frameworks from headers, meta tags, and script signatures
3	Security Header Auditor	Scores HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy
4	Cookie Analyzer	Inspects Secure / HttpOnly / SameSite flags on Set-Cookie headers
5	TLS Inspector	Reads certificate metadata (issuer, validity, expiry) from the TLS handshake
5b	Network Info Gatherer	Resolves IP address(es), TTL, reverse DNS, ASN and coarse geolocation
6	Robots/Sitemap Scanner	Parses robots.txt and sitemap.xml for disallowed-path disclosure
7	CORS Analyzer	Evaluates Access-Control-Allow-Origin configuration
8	SRI Checker	Checks external <script>/<link> tags for integrity attributes
9	Email Security Analyzer	Reads SPF and DMARC DNS TXT records
10	Security.txt Checker	Checks for an RFC 9116 vulnerability-disclosure file
11	CT Log Subdomain Finder	Passively enumerates subdomains via crt.sh Certificate Transparency logs
12	Report Generator	Aggregates findings into a weighted score and console/JSON/HTML report

C. Scoring Model

Each scan begins with a base score of 100. Every finding produced by a module carries a status of GOOD, WARNING, BAD, or INFO and an associated score_impact. GOOD and INFO findings do not alter the score; WARNING findings apply a small negative penalty (typically −3 to −5); BAD findings apply a larger penalty (typically −8 to −15), reflecting the estimated exploitability and blast-radius of the missing control (e.g., a missing CSP is penalized more heavily than a missing Referrer-Policy). The running score is clamped to the [0, 100] range after every finding is applied. This design intentionally mirrors — without exactly replicating — the additive/subtractive scoring style used by public header-scanning services, chosen for interpretability over statistical sophistication.

For cross-site aggregation, we additionally bucket every scored site into one of four risk tiers: Low Risk (≥ 85), Moderate Risk (70–84), High Risk (50–69), and Critical Risk (< 50). These tiers are used throughout Section V to summarize the distribution of posture across the dataset.

D. Execution Protocol

For each target, the orchestrator performs, in order: (i) a single GET request to the homepage with a descriptive, honest User-Agent string; (ii) technology fingerprinting and security-header auditing of that single response; (iii) cookie analysis of any Set-Cookie headers present on that response; (iv) a TLS handshake (verify=True) to the resolved hostname to read certificate metadata, performed only when the target is served over HTTPS; (v) DNS resolution and reverse-DNS/ASN lookups for network context; (vi) a single GET request to /robots.txt; (vii) analysis of the CORS header on the original response; (viii) a scan of the already-fetched HTML for externally hosted <script>/<link> tags lacking an integrity attribute; (ix) DNS TXT lookups for SPF and DMARC on the apex domain; (x) a single GET request to /.well-known/security.txt; and (xi), optionally, a read-only query to the public crt.sh Certificate Transparency log API for subdomain enumeration. No step issues more than one request per resource, and no step is repeated or retried in a way that could resemble scanning behavior.

IV. Dataset

We selected 131 production websites belonging to well-known public and private organizations, stratified across six countries and five sectors, as summarized in Table II. Site selection favored organizations with a national or near-national footprint in their sector (e.g., central banks and major retail banks; national health services and leading hospital networks; the largest daily newspapers; the dominant e-commerce platforms; and core government portals), so that the results are

representative of the sites with which the largest number of citizens actually interact.

Country	Sites	Sectors Represented
India	22	Government, Banking, Healthcare, News/Media, E-Commerce
USA	24	Government, Banking, Healthcare, News/Media, E-Commerce
UK	22	Government, Banking, Healthcare, News/Media, E-Commerce
Canada	20	Government, Banking, Healthcare, News/Media, E-Commerce
Australia	22	Government, Banking, Healthcare, News/Media, E-Commerce
Singapore	21	Government, Banking, Healthcare, News/Media, E-Commerce
Total	131	

All scans were executed between late June and early July 2026 using a single scanning host, ensuring temporal consistency across the sample. Each scan produced a structured result object containing the security score, the full list of findings with per-check status, detected technologies, cookie inventory, and network metadata, which was serialized to an HTML report per site and subsequently parsed back into a tabular dataset (131 rows × 34 features, plus a normalized long-form table of 1,934 individual findings) for statistical analysis in this study.

V. Results

A. Overall Score Distribution

Across all 131 sites, the mean security score was 72.96 (σ = 13.21), with a median of 74. Scores ranged from a minimum of 18 (an Australian e-commerce site) to a maximum of 100, achieved by two UK government sites (GOV.UK and HMRC). Fig. 1 shows the distribution of scores, which is left-skewed with a long lower tail — the majority of sites cluster between 65 and 90, but a persistent minority score below 50.

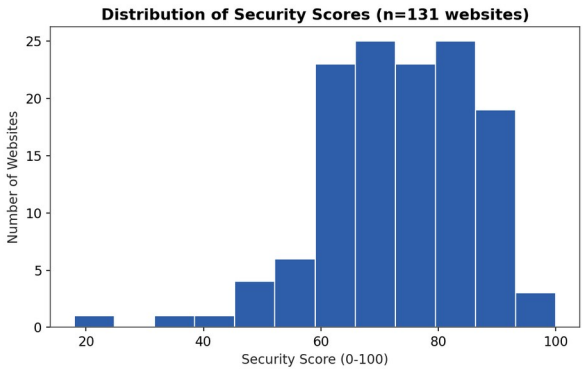


Fig. 1. Distribution of security scores across 131 websites.

Applying the four-tier risk classification from Section III-C, 26 sites (19.8%) fell into the Low Risk tier, 47 (35.9%) into Moderate Risk, 52 (39.7%) into High Risk, and 6 (4.6%) into Critical Risk (Fig. 2). In other words, roughly 44% of the assessed websites — including major national banks, hospital networks, and e-commerce platforms — carry a High or Critical passive-risk rating.

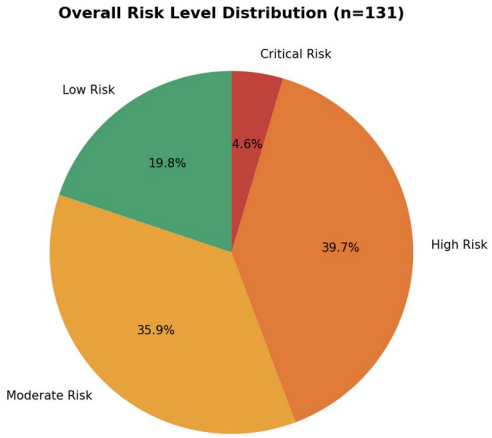


Fig. 2. Overall risk-level distribution (n = 131).

B. Country-Level Comparison

Table III and Fig. 3 summarize average security scores by country. The United Kingdom recorded the highest national average (76.3), driven substantially by its government sector (88.2 average, including two perfect scores), followed by Singapore (75.1), Australia (72.9), and India (72.8). Canada (71.6) and the United States (69.4) recorded the lowest national averages, despite the U.S. sample containing several of the highest-scoring individual sites in the entire study (e.g., Chase Bank at 92).

TABLE III. AVERAGE SCORE AND KEY HEADER ADOPTION BY COUNTRY

Country	Avg Score	Min	Max	HSTS %	CSP %	HTTPS %	DMARC %
UK	76.3	38	100	72.7	31.8	100.0	90.9

Country	Avg Score	Min	Max	HSTS %	CSP %	HTTPS %	DMARC %
Singapore	75.1	53	90	90.5	14.3	100.0	66.7
Australia	72.9	18	91	63.6	31.8	100.0	86.4
India	72.8	45	94	59.1	31.8	100.0	77.3
Canada	71.6	48	92	60.0	35.0	100.0	65.0
USA	69.4	46	92	62.5	29.2	100.0	87.5

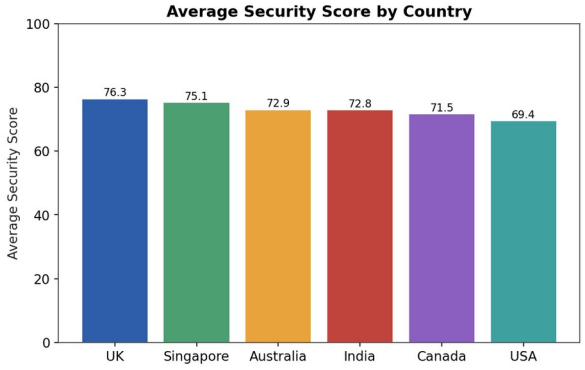


Fig. 3. Average security score by country.

Notably, HTTPS enforcement was universal — every one of the 131 sites served its homepage over HTTPS with a valid certificate — indicating that basic transport encryption is now a fully solved problem even among lower-scoring sites; the score variance is driven almost entirely by secondary controls (CSP, SRI, email anti-spoofing, and cookie hygiene) rather than by baseline TLS adoption.

C. Sector-Level Comparison

Sector proved to be a stronger predictor of security posture than country. Banking led all sectors with an average score of 80.4, followed by Government at 78.7 — both sectors subject to strict regulatory and compliance regimes (e.g., PCI-DSS, national cybersecurity directives). Healthcare scored 72.5, while E-Commerce (67.0) and News/Media (66.4) trailed substantially, as shown in Table IV and Fig. 4.

TABLE IV. AVERAGE SCORE BY SECTOR

Sector	Sites	Avg Score	HSTS %	CSP %	DMARC %
Banking	27	80.4	88.9	33.3	92.6
Government	26	78.7	76.9	26.9	76.9
Healthcare	24	72.5	54.2	20.8	75.0
E-Commerce	26	67.0	69.2	42.3	88.5
News/Media	28	66.4	50.0	21.4	64.3

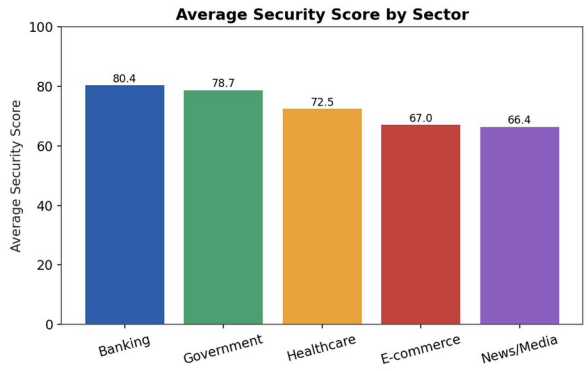


Fig. 4. Average security score by sector.

The Country × Sector heatmap in Fig. 5 shows that this sector effect holds within almost every country: Banking and Government are consistently the strongest performers, while News/Media and E-Commerce are consistently the weakest, regardless of national jurisdiction. The one clear exception is Canadian Government (63.5), which was the only Government cluster to score below its national Banking counterpart, driven by a low outlier score of 48 for Immigration, Refugees and Citizenship Canada (CIC).

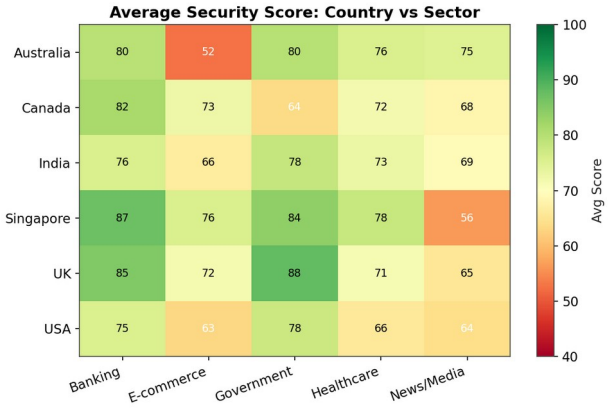


Fig. 5. Average security score by country and sector.

D. Missing and Weak Security Controls

Fig. 6 ranks the eleven audited controls by the percentage of the 131 sites that failed to implement them adequately. Subresource Integrity was effectively absent everywhere: every site in the sample that referenced at least one externally hosted script or stylesheet failed to apply an integrity attribute to it, exposing all such sites to a supply-chain compromise of that third-party host. Content-Security-Policy was missing on 71.0% of sites — including several sites that otherwise scored highly on headers — making it, together with SRI, the most under-adopted control in the study. A published security.txt vulnerability-disclosure file was absent on 68.7% of sites, Referrer-Policy was unset on 66.4%, and an SPF record was missing on 63.4% of domains, leaving a majority of organizations more exposed to email-spoofing and business-email-compromise attacks than DMARC adoption alone (79.4% present) would suggest, since SPF and DMARC serve complementary rather than substitutable roles.

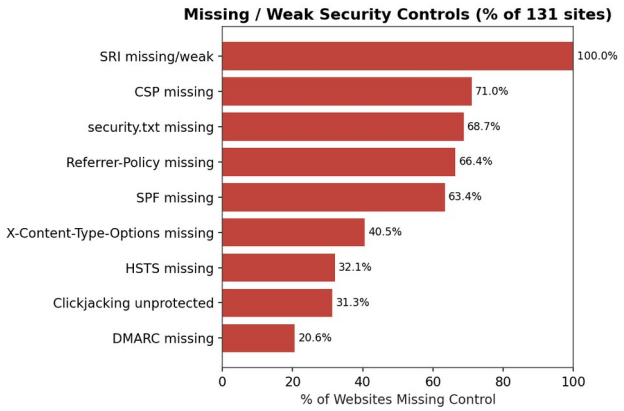


Fig. 6. Missing or weak security controls across 131 sites (percentage).

E. Cookie Security

Fig. 7 shows the distribution of cookie-related findings by country, broken into secure, warning-level, and insecure flag configurations. Cookie hygiene was the most internally inconsistent of all controls: several sites set a majority of cookies with correct Secure/HttpOnly/SameSite attributes while simultaneously leaving one or two session-identifying cookies unprotected — a pattern consistent with cookies being set by disparate third-party analytics or advertising scripts rather than by a single, centrally governed cookie policy.

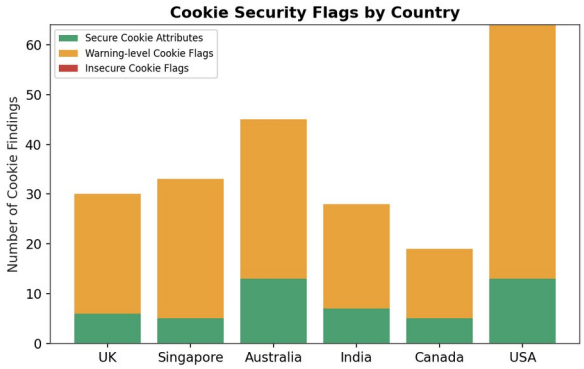


Fig. 7. Cookie security flag distribution by country.

F. Email Anti-Spoofing Controls

Fig. 8 compares SPF and DMARC adoption by country. DMARC adoption (65–91% depending on country) consistently outpaced SPF adoption (20–50%), an unusual inversion given that SPF is the older and simpler standard; we attribute this to organizations enabling DMARC in monitor-only mode (p=none) as part of a Google/Microsoft-driven 2024 bulk-sender enforcement wave, without completing the underlying SPF record configuration that DMARC alignment depends on for full protection.

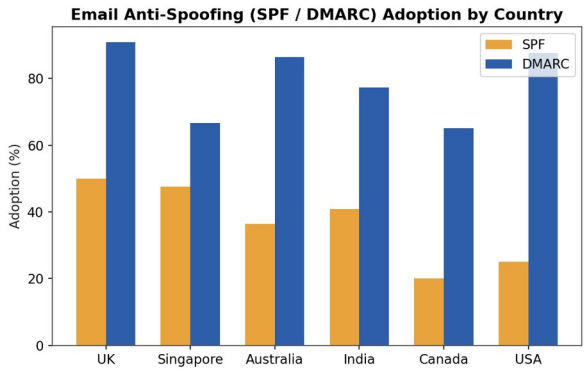


Fig. 8. SPF and DMARC adoption by country.

G. Technology Landscape

Passive fingerprinting confidently identified at least one technology on 78.6% of sites (Fig. 9). jQuery remained the single most detected client-side library (28 sites), ahead of Bootstrap (17) and React (7), reflecting the continued prevalence of legacy JavaScript stacks in large, security-sensitive organizations. Cloudflare (15 sites) and Nginx (14 sites) were the most common server/CDN signatures. No statistically meaningful correlation was found between the number of detected technologies and the security score (Pearson r = −0.10), indicating that technology modernity alone is not a reliable proxy for security posture — configuration discipline matters more than platform choice.

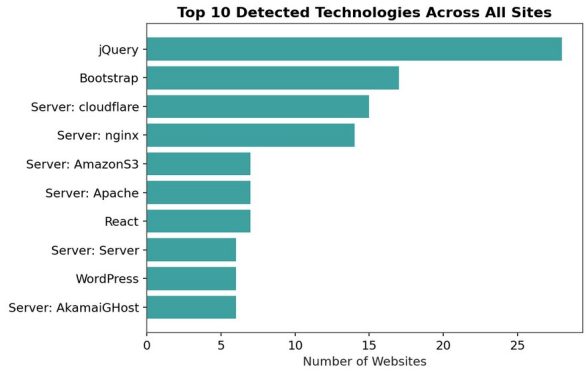


Fig. 9. Top 10 detected technologies across all sites.

H. Highest- and Lowest-Scoring Sites

Table V lists the ten highest- and ten lowest-scoring sites in the dataset. The top decile is dominated by UK and Indian government portals and major retail banks; the bottom decile spans e-commerce, news, and one banking outlier, and includes no government sites, suggesting that regulatory pressure — while not sufficient on its own — measurably reduces the probability of a site falling into the lowest tier.

TABLE V. TOP 10 AND BOTTOM 10 SITES BY SCORE

Rank	Site (Top 10)	Score	Rank	Site (Bottom 10)	Score
1	GOV.UK	100	1	eBay	18

Rank	Site (Top 10)	Score	Rank	Site (Bottom 10)	Score
	(UK, Gov)			(Australia, E-com)	
2	HMRC (UK, Gov)	100	2	Independent (UK, News)	38
3	UIDAI (India, Gov)	94	3	Canara Bank (India, Bank)	45
4	Chase (USA, Bank)	92	4	WebMD (USA, Health)	46
5	Staples (Canada, E-com)	92	5	Etsy (USA, E-com)	47
6	NatWest (UK, Bank)	91	6	CIC (Canada, Gov)	48
7	SMH (Australia, News)	91	7	Best Buy (Canada, E-com)	51
8	Barclays (UK, Bank)	90	8	Mothership (Singapore, News)	53
9	National Archives (UK, Gov)	90	9	Straits Times (Singapore, News)	53
10	Australia.gov.au (Gov)	90	10	eBay (USA, E-com)	54

VI. Discussion

A. Compliance Pressure Predicts Posture Better Than Geography

The consistent Banking > Government > Healthcare > E-Commerce ≈ News/Media ordering, reproduced within almost every country independently, suggests that sector-specific regulatory and audit pressure (PCI-DSS for payment card handling, national cybersecurity directives for government and critical infrastructure, and clinical-data protection regimes for healthcare) is a stronger driver of passive security posture than national jurisdiction. This is consistent with the view that formal compliance obligations translate into concrete engineering practices — CSP rollout, DMARC enforcement, structured cookie policies — more reliably than general national cybersecurity maturity.

B. Content-Security-Policy and SRI Remain the Two Weakest Links

The near-total absence of Subresource Integrity and the 71% absence of CSP are the most actionable findings of this study. Both controls specifically defend against third-party JavaScript compromise (e.g., a compromised CDN, ad network, or analytics vendor silently injecting malicious code) — a threat model that has caused real-world breaches (e.g., Magecart-style skimming attacks against e-commerce checkout pages). Our finding that E-Commerce sites have simultaneously the highest CSP adoption of any sector (42.3%) and zero meaningful SRI adoption suggests that organizations are aware of the header-based defense but have not extended that awareness to the script-tag level, leaving a specific and well-documented attack surface open even at security-conscious organizations.

C. Universal HTTPS but Inconsistent Secondary Hardening

That 100% of sampled sites enforce HTTPS, while scores still range from 18 to 100, confirms that TLS adoption alone is no longer a differentiator of web security maturity in 2026; it is a baseline expectation. The variance we observe is concentrated in secondary, defense-in-depth controls (CSP, SRI, Referrer-Policy, Permissions-Policy, cookie flags) that require more engineering discipline to implement correctly and are not enforced by browsers or certificate authorities by default, and therefore are far more sensitive to organizational security culture than to raw technical capability.

D. The SPF/DMARC Inversion

The observation that DMARC adoption outpaces SPF adoption in every country studied is, to our knowledge, an under-reported pattern. Because DMARC's protective value depends on either SPF or DKIM alignment, a DMARC record without a corresponding SPF record provides only partial protection and may create a false sense of security among stakeholders who see 'DMARC: present' in a compliance checklist without verifying the underlying alignment mechanism actually functions.

VII. Threats to Validity and Ethical Considerations

A. Construct Validity

The 0–100 score is a weighted heuristic, not a formally derived risk metric; the relative penalty weights (Section III-C) reflect the authors' judgment of exploitability and are not calibrated against historical breach data. Two sites with the same score may have materially different real-world risk if the underlying penalty composition differs.

B. Internal Validity

All scans reflect a single point-in-time snapshot (late June – early July 2026). Security headers, CDN configuration, and DNS records can change rapidly (e.g., during a CDN migration or an A/B test), so individual site scores should be treated as a snapshot rather than a permanent rating. Homepage-only scanning also means the assessment does not capture security posture on deeper, more sensitive pages (e.g., login or checkout flows) that may differ from the homepage.

C. External Validity

The sample of 131 sites, while stratified, is not randomly drawn and over-represents the largest, most prominent organization in each sector-country cell; smaller and mid-sized organizations, which plausibly have weaker security engineering resources, are not represented and would likely lower the reported averages if included.

D. Ethical and Legal Considerations

Although every request issued by the framework is indistinguishable from an ordinary browser visit, the authors restricted testing to publicly accessible homepages and public DNS/CT-log records, used a descriptive and honest User-Agent string, respected robots.txt where scanning behavior could be construed as automated crawling, and did not attempt to access, modify, or exfiltrate any non-public data. Researchers intending to reproduce or extend this study should independently confirm that passive scanning of third-party infrastructure is permissible under applicable computer-misuse law in their jurisdiction, since legality of even passive, unauthenticated requests can vary by jurisdiction and by the target's terms of service.

VIII. Conclusion and Future Work

This paper presented a twelve-module passive web security assessment framework and applied it to 131 production websites across six countries and five sectors, producing what is, to our knowledge, one of the largest publicly documented cross-national passive security comparisons to date. The mean security score of 72.96 masks substantial underlying variance: nearly half of the sampled sites fall into the High or Critical risk tier once secondary hardening controls are accounted for, and two controls — Content-Security-Policy and Subresource Integrity — are so under-adopted across every country and sector that they represent the single highest-leverage improvement available to the majority of the organizations studied. Sector-specific regulatory pressure was found to be a substantially stronger predictor of posture than national jurisdiction, with Banking and Government consistently outperforming News/Media and E-Commerce in every country sampled.

Future work should extend the framework in three directions: (1) longitudinal re-scanning of the same 131 sites to measure posture drift over time and correlate score changes with publicly disclosed breach or incident data; (2) expansion beyond the homepage to authenticated and transactional flows using consented, authorized testing partnerships, to validate whether homepage posture correlates with posture on higher-risk pages; and (3) calibration of the scoring weights against a labeled dataset of historical incidents, moving the framework from a heuristic risk indicator toward a statistically validated predictor of breach likelihood.

References

[1] OWASP Foundation, "OWASP Secure Headers Project," 2025. [Online]. Available: https://owasp.org/www-project-secure-headers/

[2] Mozilla Foundation, "HTTP Observatory," 2025. [Online]. Available: https://developer.mozilla.org/en-US/observatory

[3] Internet Engineering Task Force, RFC 6797: HTTP Strict Transport Security (HSTS), Nov. 2012.

[4] W3C, "Content Security Policy Level 3," W3C Working Draft, 2023.

[5] W3C, "Subresource Integrity," W3C Recommendation, June 2016.

[6] Internet Engineering Task Force, RFC 7208: Sender Policy Framework (SPF), Apr. 2014.

[7] Internet Engineering Task Force, RFC 7489: Domain-based Message Authentication, Reporting and Conformance (DMARC), Mar. 2015.

[8] Internet Engineering Task Force, RFC 9116: A File Format to Aid in Security Vulnerability Disclosure, Apr. 2022.

[9] B. Laurie, A. Langley, and E. Kasper, RFC 6962: Certificate Transparency, June 2013.

[10] Qualys SSL Labs, "SSL Server Test Methodology," 2025. [Online]. Available: https://github.com/ssllabs/research

[11] S. Van Acker, D. Hausknecht, and A. Sabelfeld, "Measuring login webpage security," in Proc. 32nd ACM SAC, 2017, pp. 1753–1760.

[12] P. Kotzias, A. Razaghpanah, J. Amann, K. G. Paterson, C. Vallina-Rodriguez, and J. Caballero, "Coming of age: A longitudinal study of TLS deployment," in Proc. Internet Measurement Conf. (IMC), 2018.

[13] Internet Engineering Task Force, RFC 6454: The Web Origin Concept, Dec. 2011 (basis for CORS behavior).

[14] Google Safe Browsing Team, "State of the web: HTTPS adoption trends," Transparency Report, 2025.